



FUNDAMENTALS OF INFORMATION SECURITY

SESSION 9

COURSE CODE:

CYBE 6123

LECTURER: **NGUEMETA NATHANIEL**



Security Operations and Administration

Objective of the session

- What security administration is
- What compliance is
- What professional ethics are
- What the infrastructure for an information technology (IT) security policy is
- What data classification standards are
- What configuration management is
- What the change management process is
- What the system life cycle (SLC) and system development life cycle (SDLC) are
- How software development relates to security

Security Administration



- **Sensitive assets list**—What assets must the organization take measures to secure?
- **The organization's security process**—How does it all work?
- **The authority of the persons responsible for security**—Which administrator is responsible or authorized for what assets and actions?
- **The policies, procedures, and guidelines** adopted by the organization—What information needs to be communicated, how is it communicated, and when is it communicated?

Security Outsourcing



- **Advantages**

- An external security management firm has a high level of expertise because it focuses on security

- **Disadvantages**

- The outsourcing firm might not know the organization well nor possess enough internal knowledge necessary to protect its assets.
- The organization will not be developing its own in-house capability for security management, hence they remain dependent

Security Outsourcing - Considerations



- **Privacy**—Does the third party agree to uphold the organization's privacy policy? How does it plan to control how data is collected, stored, handled, and destroyed?
- **Risk**—What additional risks exist by transferring data over a trust boundary? How are any new risks addressed? Who is responsible for managing new outsourcing risks?
- **Data security**—What controls protect data confidentiality and integrity from unauthorized access? Are access controls consistent with internal controls? How is data availability protected? Are backups and redundancy measures in place to minimize downtime? How are back-ups and redundant data copies protected?
- **Ownership**—Who owns the data, the infrastructure, and the media? Who is responsible for each component?
- **Adherence to policy**—Does the third party commit to upholding the organization's security policies and procedures?

Security Outsourcing - Considerations

- Service level agreement (SLA)
- Blanket purchase agreement (BPA)
- Memorandum of understanding (MOU)
- Interconnection security agreement (ISA)

Compliance



- **Definition**

- The state or fact of according with or meeting rules or standards.
- Requires clear statements and unambiguous criteria

- **Principles**

- Adherence to criteria of operations
- Requires details pertaining to different aspects of governance and operations
- Can be regulatory, legal, contractual, or policy-based
- Bottom-line is to provide common perspective and baseline practices

Ensuring Compliance



- **Event logs**
 - Record of actions taken on systems
 - Very useful to detect incidents and intrusion in the early stages
 - Requires proper fine-tuning
- **Compliance liaison**
 - Monitors and reports on adherence to company policies
 - Assists in understanding of compliance requirements, and provides necessary training
- **Remediation**
 - Helps in mitigating risks and responding to incidents should they occur
 - Monitors and responds to vulnerabilities which could affect the environment

Professional Ethics



- **Set the example**— Security professionals must demonstrate strong ethical principles in their daily activities so that users will follow their lead.
- **Encourage adopting ethical guidelines and standards**—Security professionals must know their ethical boundaries and set an example by adhering to them,
- **Inform users through security awareness training**—Security professionals must ensure that users are aware of and understand their ethical responsibilities.

Personnel Security Principles

- **Limiting Access**
 - Separation of Duties
 - Job Rotation
 - Mandatory Vacations
 - Security Training
 - Security Awareness
- Social Engineering
 - Intimidation
 - Name-dropping
 - Appeals for help
 - Phishing

Organizational Security Policy



FIGURE 9-1 The security policy environment.

Organizational Security Policy

Organizational Security Policy

Statement by top-level management that security is important to the organization and that activities pursuant to a secure state will be recognized, supported, and funded

Functional Policies in Support of Organizational Policy

(These are some examples)

Acceptable Use

Antivirus

Interconnection

Email Use

Firewall

Host Security

Wireless Use

Extranet

Other Policies

Supporting Mechanisms

Standards

Define specific products and mechanisms used to support policy

Procedures

Define actions to implement policy, standards, and baselines

Baselines

Define minimum required parameters to achieve a consistent security level

Guidelines

Define recommended (yet not required) actions

Data Classification



- **Value**

- Value to the organization;
- Value to competitors;
- Cost of replacement or loss;
- Value to the organization's reputation.

- **Sensitivity**

- Liability or fines, reputation, credibility, or loss of market share.

- **Criticality**

- Importance of the information to the mission of the organization

Data Classification Levels

DATA CLASSIFICATION LEVELS



Configuration Management



- Implement a standard naming convention consists of well-defined labels that indicate a component's function and perhaps even location
- Maintain an up-to-date layout of the configuration of all hardware components
- Keep copies of all software configurations so that you can examine changes and planned updates

The Change Management Process

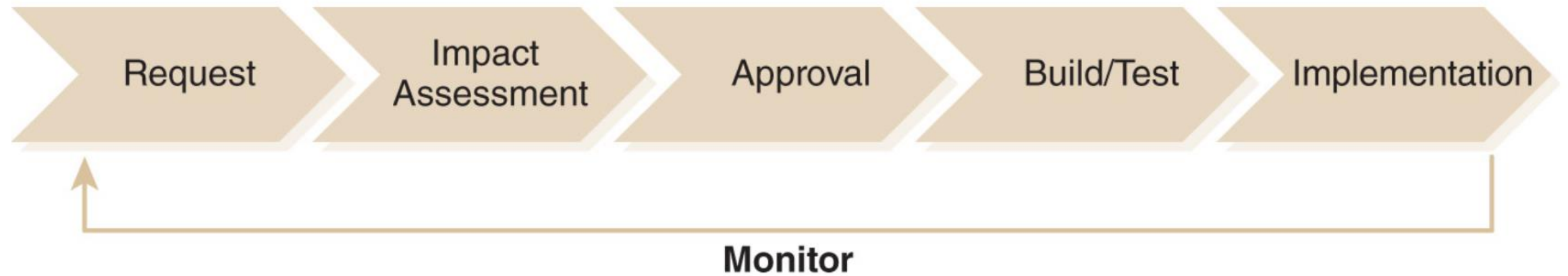
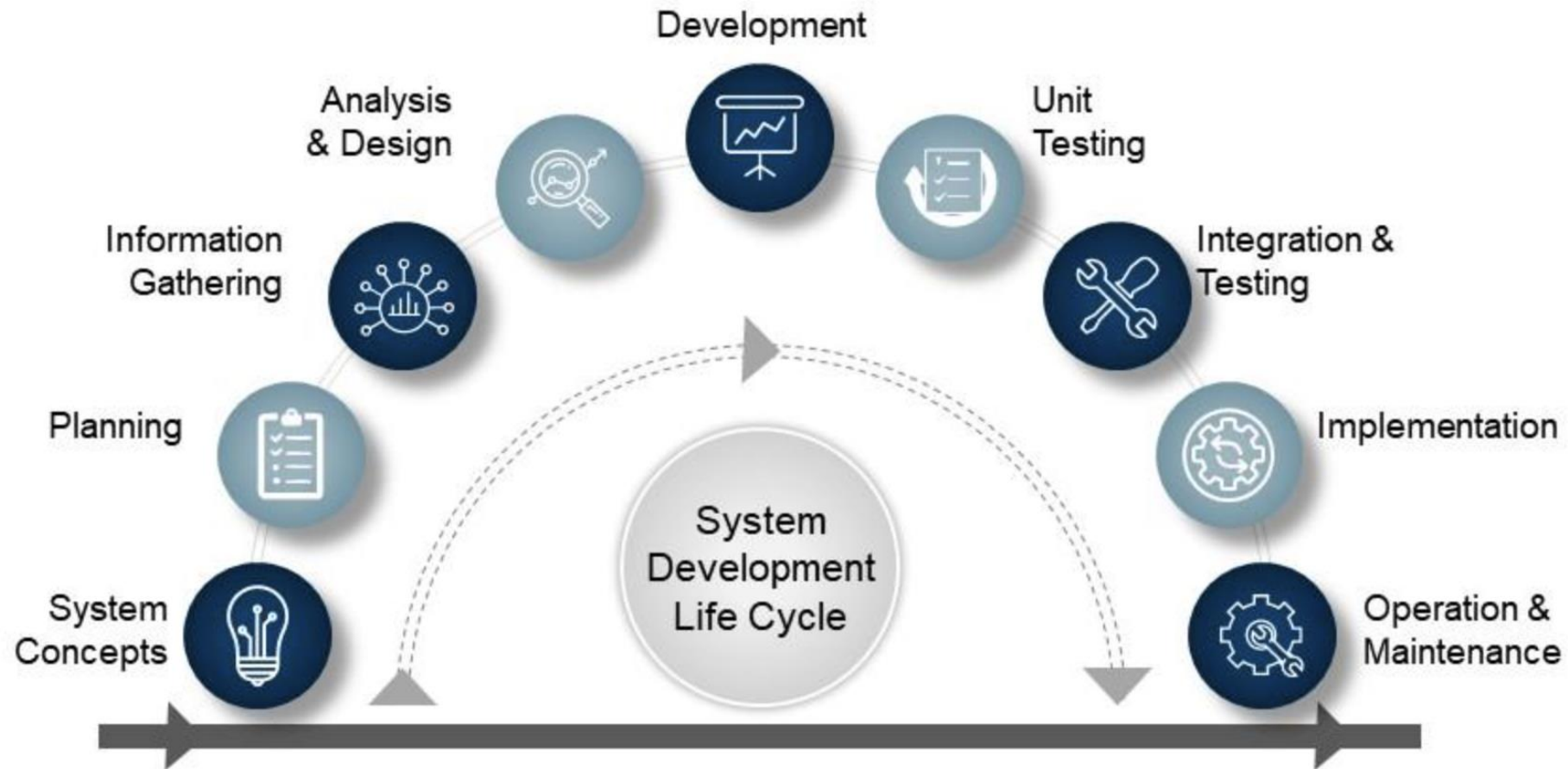


FIGURE 9-5 Change control procedures.

Application Software Security



Assignment

- List and describe 5 defense mechanisms against malware.
- Complete and submit assessment.



Thank You